

Laboratório PortSwigger: Web Cache Deception

Web Cache Deception

Web Cache Deception é uma vulnerabilidade de segurança em que um invasor induz um servidor de cache, como uma CDN, a armazenar dados privados e dinâmicos de um usuário. Como consequência, essas informações podem ficar acessíveis publicamente e serem visualizadas por usuários não autorizados.

Vulnerabilidade

- Confusão de rotas (Path Confusion): ocorre quando o servidor de origem e o proxy de cache interpretam a URL de maneiras diferentes.
- Extensões estáticas: o cache pode ser configurado para armazenar arquivos com base apenas em suas extensões, como .css ou .jpg, ignorando outros controles aplicados à resposta.
- Requisição forjada: o invasor cria uma URL que combina uma página sensível com uma extensão associada a recursos estáticos, por exemplo: /perfil/dados.css.
- Armazenamento indevido: quando uma vítima autenticada acessa essa URL, o servidor de origem pode processar uma página privada, enquanto o cache interpreta a resposta como um recurso estático e a armazena.

Impacto

- Vazamento de dados: exposição de informações pessoais, extratos, chaves de API ou tokens de sessão.
- Acesso não autorizado: um invasor pode acessar a URL criada e visualizar dados de uma vítima que tenham sido armazenados no cache.
- Roubo de contas: tokens comprometidos podem permitir o controle total da conta do usuário afetado.

Informações e acessos fornecidos pelo laboratório

- Credenciais de acesso para um usuário comum, sem privilégios administrativos.
- Página inicial (Home).
- Página de conta (My Account).

Metodologia de exploração

1. Identificar endpoints que retornam informações ou conteúdo dinâmico utilizando o Burp Suite.
2. Identificar discrepâncias na forma como o cache e o servidor de origem analisam o caminho da URL. Essas diferenças podem ocorrer no mapeamento de URLs para recursos, no processamento de caracteres delimitadores ou na normalização de caminhos.
3. Criar uma URL utilizando a discrepância identificada para induzir o cachê a armazenar uma resposta dinâmica. Quando a vítima acessar essa URL, a resposta pode ser armazenada no cache.

1º Laboratório: Explorando o mapeamento de caminhos para enganar o cache da web

Instrução: encontrar a chave de API do usuário Carlos. O laboratório fornece acesso a uma conta própria utilizando as credenciais disponibilizadas no ambiente.

Conhecimentos necessários

- Como endpoints baseados em expressões regulares mapeiam caminhos de URL para recursos.
- Como detectar e explorar discrepâncias na forma como o cache e o servidor de origem mapeiam os caminhos de URL.

Construção e análise do ataque

A partir do objetivo do laboratório e da análise da conta fornecida, foi identificado o endpoint My Account, que retornava uma resposta dinâmica contendo uma chave de API.

Em seguida, foram analisadas as regras de cache e identificadas extensões associadas a recursos estáticos, como .css e .js. Também foram investigadas discrepâncias na forma como o cache e o servidor de origem mapeavam os caminhos das URLs.

Após a identificação dessas diferenças de comportamento, foi possível construir uma requisição utilizando o caminho que explorava a discrepância observada e enviá-la ao usuário-alvo do laboratório, permitindo obter a chave de API solicitada.

Análise do comportamento do cache

Durante os testes, a utilização de um caminho associado a um recurso estático, como resources.js, permitiu identificar alterações nos cabeçalhos relacionados ao cache. Foram observados os cabeçalhos Cache-Control, Age e X-Cache.

Em uma nova requisição, o cabeçalho Cache-Control apresentou max-age=30, indicando que o recurso poderia ser armazenado temporariamente. Também foi observada a alteração do cabeçalho X-Cache de miss para hit, demonstrando que a resposta passou a ser servida pelo cache.

Conclusão

Após identificar o conteúdo dinâmico, os recursos estáticos e as discrepâncias no mapeamento dos caminhos, foi possível construir a requisição necessária para explorar o comportamento do cache dentro do ambiente controlado do laboratório e alcançar o objetivo proposto.